

Security+ 2.4 · Indicators of Compromise

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —

Indicators of Compromise (10:59) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Indicators of Compromise (IOCs) are artifacts that suggest a system may have been breached. Examples include a series of account lockouts (password spraying), impossible travel (logins from geographically distant locations within an impossible timeframe), abnormal resource consumption (CPU, network egress), logins at unusual hours, and baseline deviations. Technical IOCs include malicious IP addresses, file hashes, and C2 domains. Defenses involve EDR/SIEM correlation, threat feeds, and time-based alerting.

High-Yield Core Concepts Tested on Exam

- IOC: malicious IP, malware hash, C2 domain — technical evidence of compromise.
- Impossible travel: login from two distant locations within a timeframe that makes physical travel impossible.
- Series of account lockouts: indicates brute force or password spraying in progress.
- Abnormal resource consumption: unexpected CPU, memory, or network egress may indicate malware.
- Defense: EDR/SIEM correlation, threat intelligence feeds, and alerting on anomalies.

Exam Tips & Classic Scenarios

- 'login from two distant locations within minutes' = impossible travel (IOC).
- 'IP address known to be malicious' = IOC.
- 'multiple account lockouts' = password spraying or brute force.

Typical Exam Scenario: A user logs in from São Paulo at 9:00 AM and from Lisbon at 9:05 AM. This is impossible travel, an indicator of compromise suggesting credential theft. The account should be investigated and secured.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Indicators of Compromise)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **IOC:** Indicator of Compromise: Forensic evidence identifying unauthorized intrusion remnants (e.g. known malware hash, C2 IP, altered registry keys).
- **MITRE ATT&CK:** Globally accessible knowledge base cataloging real-world cyber adversary tactics, techniques, and common procedures (TTPs).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. The 'encyclopedia' of attacker tactics and techniques that the SOC uses as a map is:

- A)** OWASP Top 10
- B)** MITRE ATT&CK
- C)** ISO 27001
- D)** PCI-DSS

2. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

3. `x = 5\n``def change():\n global x\n x = 10\n``change()\nprint(x)`

- A)** 5
- B)** 10
- C)** Error
- D)** None

4. Corporate scenario (Indicators of Compromise): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'IOC = malicious IP, malware hash, C2 domain — technical clue'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: IOC = malicious IP, malware hash, C2 domain — technical clue...
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Indicators of Compromise): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Impossible travel = geographically impossible login within the time window'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Impossible travel = geographically impossible login within the time window...

6. Corporate scenario (Indicators of Compromise): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Serial account lockout = brute force/spraying in progress'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Serial account lockout = brute force/spraying in progress...

7. Corporate scenario (Indicators of Compromise): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'login from two distant locations within minutes' = impossible travel (IOC). What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'login from two distant locations within minutes' = impossible travel (IOC)...

8. Corporate scenario (Indicators of Compromise): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'IP address known to be malicious' = IOC. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'IP address known to be malicious' = IOC...

9. Corporate scenario (Indicators of Compromise): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: user logs in from São Paulo at 9:00 AM and from Lisbon at 9:05 AM = impossible travel (indicator of compromise).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: 'user logs in from São Paulo at 9:00 AM and from Lisbon at 9:05 AM' = impossible travel (indicator of compromise).
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Indicators of Compromise): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'IOC = malicious IP, malware hash, C2 domain — technical clue'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: IOC = malicious IP, malware hash, C2 domain — technical clue...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — MITRE ATT&CK.

✓ **Why it is correct:** MITRE ATT&CK is a globally accessible knowledge base that documents adversary tactics, techniques, and procedures (TTPs) observed in real-world attacks. It is organized into matrices (Enterprise, Mobile, ICS) and serves as a map for SOC (Security Operations Center) teams to understand attacker behavior, prioritize detections, and align defenses. In CompTIA Security+ (SY0-701), MITRE ATT&CK is explicitly cited as an essential tool for threat analysis and incident response. The statement describes an 'encyclopedia' of tactics and techniques used as a map by the SOC, which exactly matches the purpose of MITRE ATT&CK.

✗ **Why the others are wrong:**

- *OWASP Top 10*: The OWASP Top 10 is a list of the ten most critical web application security risks, such as SQL injection, broken authentication, and sensitive data exposure. It focuses on secure development and application testing, not on general attacker tactics and techniques. Although an important reference, it is not an 'encyclopedia' of adversary TTPs used by the SOC to map attack behaviors across the infrastructure. Therefore, it does not apply to the described context.
- *ISO 27001*: ISO/IEC 27001 is an international standard that specifies requirements for establishing, implementing, maintaining, and improving an Information Security Management System (ISMS). It provides a governance and compliance framework, not a catalog of attacker tactics and techniques. The SOC does not use it as a 'map' of adversary behavior, but rather as a reference for organizational policies and controls. Thus, it is not the correct answer for the statement.
- *PCI-DSS*: PCI-DSS (Payment Card Industry Data Security Standard) is a set of security requirements for organizations that handle credit card data. It focuses on regulatory compliance and protection of payment data, not on cataloging attacker tactics and techniques. The SOC may use PCI-DSS for audits, but not as an encyclopedia of TTPs. Therefore, it does not meet the description.

2) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive*: These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review*: This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do,

Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.

- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

3) B — 10.

✓ **Why it's correct:** The code defines a global variable `x = 5`. Then it defines a function `change()` that, when called, uses the global keyword to declare that `x` refers to the global variable, and then assigns 10 to it. After the function call, the global variable `x` has been modified to 10. Therefore, the output of `print(x)` is 10. This behavior is typical of languages like Python, where the global keyword allows modifying variables outside the local scope. In the context of CompTIA Security+, although not a security topic directly, programming logic questions may appear in exams to assess technical reasoning.

✗ **Why the others are wrong:**

- *5*: This alternative would be correct if the `change()` function did not have the global keyword or if it had created a local variable `x`. Without `global`, the assignment `x = 10` inside the function would create a new local variable, and the global variable would remain 5. However, the code explicitly uses `global x`, so the global variable is changed. The alternative is wrong because it ignores the effect of the global declaration.
- *Error*: There is no error in the code. The syntax is correct: the function is defined, the global keyword is used properly, and the `change()` call occurs before `print`. An error would occur if, for example, the variable `x` did not exist in the global scope before the function, but it does (`x = 5`). Therefore, the alternative is incorrect because the code runs without errors.
- *None*: `None` would be the result if the `change()` function did not modify `x` and if `print(x)` printed the return value of `change()`, but `change()` returns nothing (implicitly returns `None`). However, `print(x)` prints the variable `x`, not the function's return value. Since `x` was modified to 10, the output is 10, not `None`. The alternative is wrong because it confuses the function's return value with the value of the global variable.

4) C — Implement the corresponding solution: IOC = malicious IP, malware hash, C2 domain — technical clue....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Indicators of Compromise): IOC = malicious IP, malware hash, C2 domain — technical clue. Indicators of Compromise (IOCs) are artifacts observed on a network or in an operating system that with high confidence indicate a computer intrusion, such as malicious IP addresses, file hashes, and command-and-control (C2) domains.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: This destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: Impossible travel = geographically impossible login within the time window....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Indicators of Compromise): Impossible travel = geographically impossible login within the time window. This indicator detects when a user account logs in from two geographically distant locations within a timeframe that makes physical travel impossible, suggesting compromised credentials.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Serial account lockout = brute force/spraying in progress....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Indicators of Compromise): Serial account lockout = brute force/spraying in progress. Multiple account lockouts indicate an ongoing brute force or password spraying attack, which is a key indicator of compromise.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'login from two distant locations within minutes' = impossible travel (IOC)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Indicators of Compromise): 'login from two distant locations within minutes' = impossible travel (IOC).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: 'IP address known to be malicious' = IOC....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Indicators of Compromise): 'IP address known to be malicious' = IOC.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: Scenario: 'user logs in from São Paulo at 9:00 AM and from Lisbon at 9:05 AM' = impossible travel (indicator of compromise)..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Indicators of Compromise): Scenario: 'user logs in from São Paulo at 9:00 AM and from Lisbon at 9:05 AM' = impossible travel (indicator of compromise). Impossible travel is a behavioral IoC where authentication events from geographically distant locations within a timeframe that precludes physical travel indicate potential credential compromise. The correct response is to implement detection and alerting for this indicator, typically via SIEM correlation rules, UEBA, or identity analytics.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: IOC = malicious IP, malware hash, C2 domain — technical clue....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Indicators of Compromise): IOC = malicious IP, malware hash, C2 domain — technical clue. IOCs are pieces of forensic data that indicate a potential intrusion, such as unusual network traffic, malicious file hashes, or command-and-control domains.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the

Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or executed malicious commands.